

Technical Assessment: Multi-Value Single-Column SQL Injection

Assessor: Moe Htet Ar Kar (Phoe Cho) **Date:** July 2026

1. Vulnerability Identified

- **Single-Column SQL Injection** with Data Aggregation (CWE-89)

2. Proof of Concept (PoC)

1. Identified a UNION-based SQLi vulnerability in the product category filter, but discovered that the application only renders **one single text column** in the UI response.
2. Bypassed this application display limitation by utilizing backend database string concatenation operators (`||` or `CONCAT`).
3. Crafted and injected a specialized payload: `' UNION SELECT NULL, username || ':' || password FROM users--`.
4. Extracted both fields simultaneously as a single combined string (e.g., `administrator:password123`) inside the visible UI element.

3. Impact

Attackers can extract complete database records even when the application heavily limits the number of displayed columns.

4. Remediation

- Enforce **Parameterized Queries** to ensure user inputs are treated strictly as data, not executable queries.
- Avoid combining user input directly into SQL execution strings.